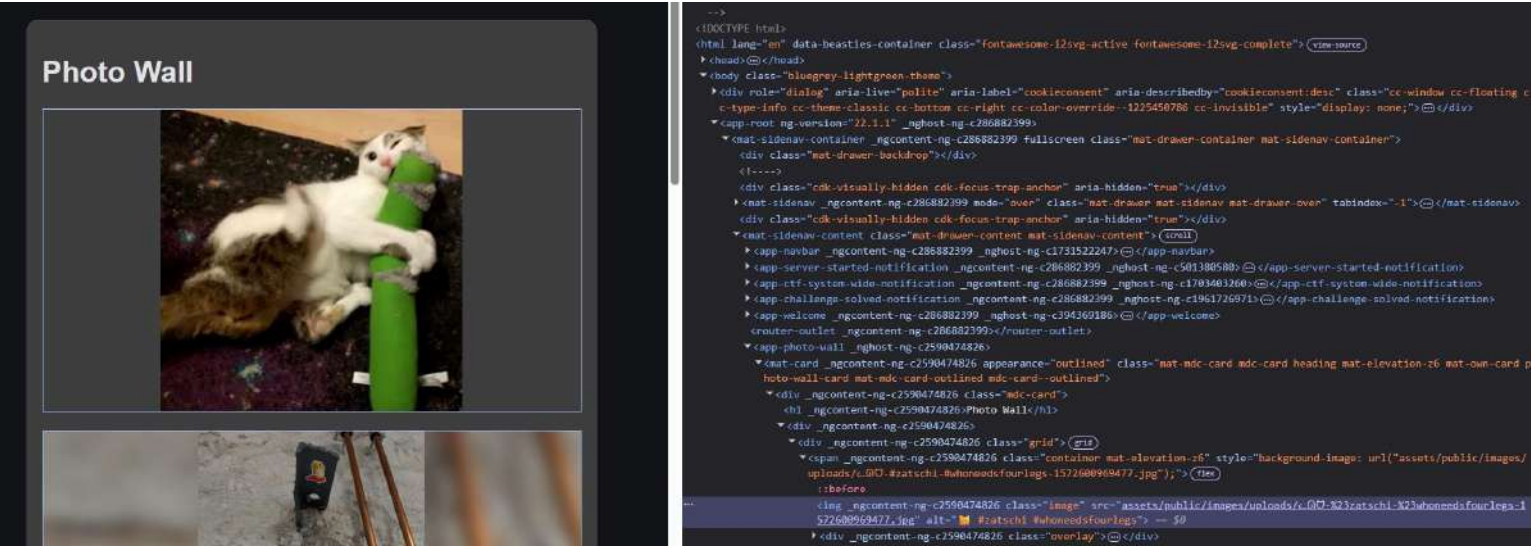


Desafio OWASP Juice Shop

Aluno: Andriw Amorim Santarém

Desafios iniciais:

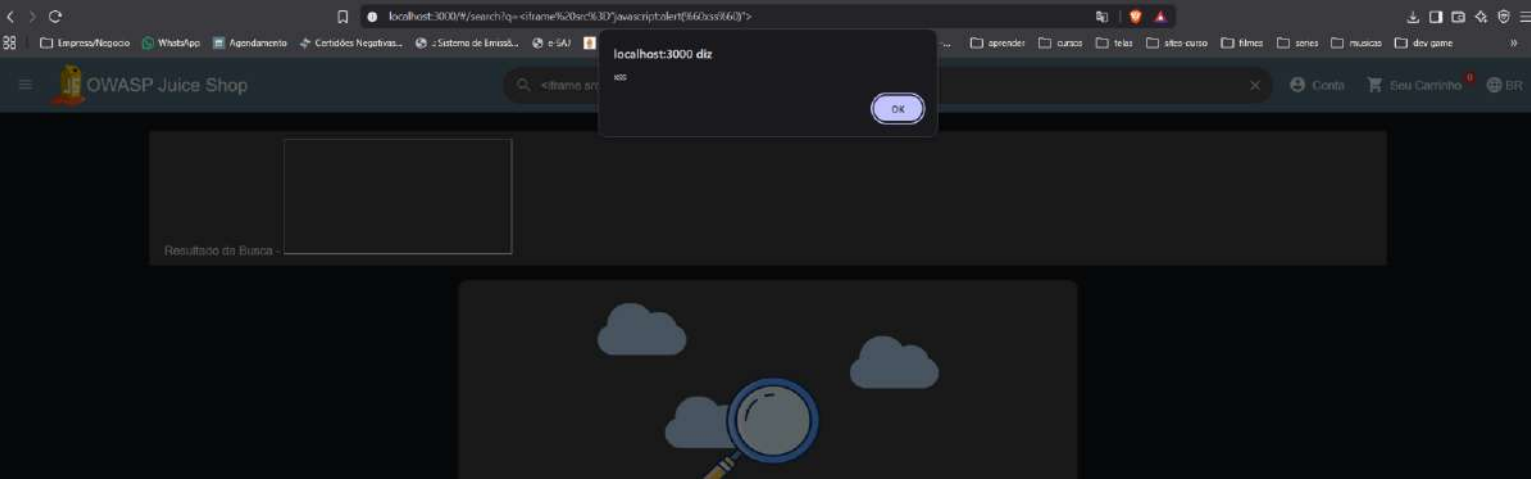
Do gago era %23 que tinha que ser alterado do # podia fazer isso pelo console ou alterando direto que eu fiz:



Ta tando erro ao receber a resposta (qualquer pergunta é a mesma resposta):



Doom frame injeção:



Documento confidencial :



localhost:3000/rest/qwertz

OWASP Juice Shop (Express ^4.22.1)

500 Error: Unexpected path: /rest/qwertz

at /juice-shop/build/routes/angular.js:18:18
at /juice-shop/build/lib/utils.js:235:26
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/build/routes/verify.js:235:5
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)
at /juice-shop/node_modules/express/lib/router/index.js:286:9
at router.process_params (/juice-shop/node_modules/express/lib/router/index.js:346:12)
at next (/juice-shop/node_modules/express/lib/router/index.js:280:10)
at /juice-shop/build/lib/insecurity.js:218:5
at Layer.handle [as handle_request] (/juice-shop/node_modules/express/lib/router/layer.js:95:5)
at trim_prefix (/juice-shop/node_modules/express/lib/router/index.js:328:13)

Redirecionando para o blockchain:

<http://localhost:3000/redirect?to=https://blockchain.info/address/1AbKfgvw9psQ41NbLi8kufDQTezwG8DRZm>

Repetir senha:

Você resolveu com sucesso o desafio: Repetitive Registration (Follow the DRY principle while registering a user.)

Cadastro de usuário

Email must be unique

Email*

teste@gmail.com

Senha*

Senha deve ter de 5-40 caracteres.

7/20

Repita a senha*

Exibir dica de senha

6/40

Proponha de segurança *

Mother's maiden name?

Isso não poderá ser alterado mais tarde!

Resposta*

losie

Cadastre-se

Já é um cliente?

Sumir 3 notificacoes com shift:

OWASP Juice Shop

You successfully solved a challenge: Mass Dispel (Close multiple "Challenge solved"-notifications in one go.)

10%

0%

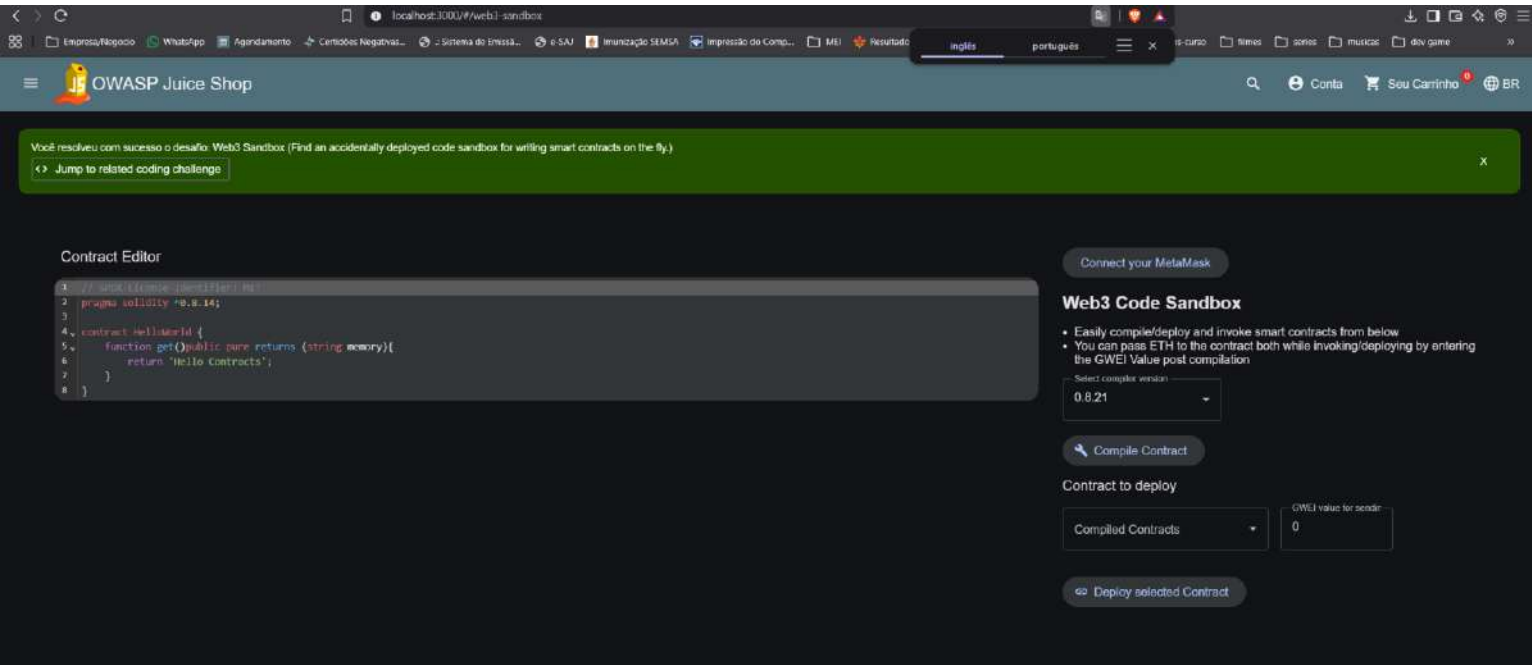
12/188

11/27

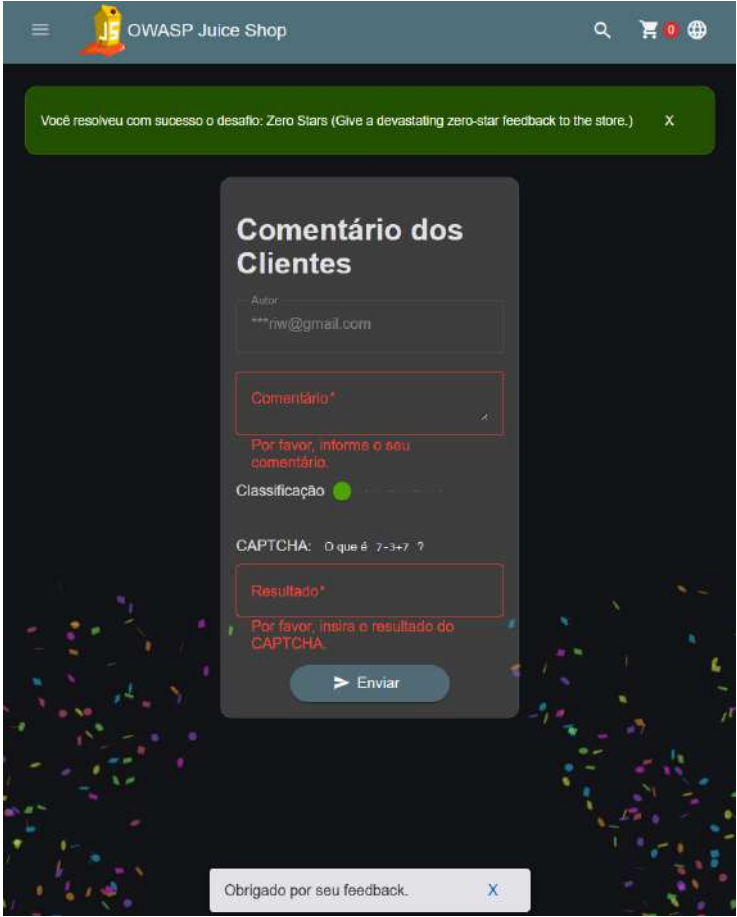
1/29

0/51

Web sandbox:



Button disable:



Desafio de 1 estrela:

Q

Pesquisar

Nível de Dificuldade

1

Status

Tags

All

Broken Access Control

XSS

Observability Failures

Improper Input Validation

Unvalidated Redirects

Vulnerable Components

Broken Authentication

Security through Obscurity

Insecure Deserialization

Broken Anti Automation

Injection

Sensitive Data Exposure

Security Misconfiguration

Cryptographic Issues

Miscellaneous

XXE

18 challenges are unavailable on Docker due to security concerns or technical incompatibility!

Show them anyways

Miscellaneous

Score Board

Encontre e placar de pontos muito bem escondido.

Tutorial

Análise de código

With Coding Challenge

XSS

DOM XSS

Realize um ataque XSS do tipo DOM com o código cifrado: `src="javascript:alert('xss')"`.

Tutorial

Bon para demonstrações

With Coding Challenge

XSS

Bonus Payload

Use the Bonus payload `<iframe width="100%" height="100%" scrolling="no" frameborder="no" allow="autoplay" src="https://w.soundcloud.com/player/?...">`

Miscellaneous

Tutorial

With Coding Challenge

Miscellaneous

Privacy Policy

Read our privacy policy.

Bon para demonstrações

Tutorial

Bon para demonstrações

Sensitive Data Exposure

Confidential Document

Acesse um documento confidencial.

Bon para demonstrações

With Coding Challenge

Security Misconfiguration

Error Handling

Provoke an error that is neither very gracefully nor consistently handled.

Full module

Observability Failures

Exposed Metrics

Find the endpoint that serves usage data to be scraped by a popular monitoring system.

Bon para demonstrações

With Coding Challenge

Miscellaneous

Mass Dispel

Close multiple "Challenge solved" notifications in one go.

Improper Input Validation

Missing Encoding

Retrieve the photo of Bjoern's cat in "index combat mode".

Miscellaneous

Unvalidated Redirects

Outdated Allowlist

Let us redirect you to one of our crypto currency addresses which are not promoted any longer.

Análise de código

With Coding Challenge

Improper Input Validation

Repetitive Registration

Follow the DRY principle while registering a user.

Broken Access Control

Web3 Sandbox

Find an accidentally deployed code sandbox for writing smart contracts on the fly.

Web3

With Coding Challenge

Improper Input Validation

Zero Stars

Give a devastating one-star feedback to the store.

Injeção de ' OR 1=1—

J5

OWASP Juice Shop

Você resolveu com sucesso o desafio: Login Admin (Log in with the administrator's user account.)

<> Jump to related coding challenge

Todos os Produtos

Senha e login pro admin é admin@juice-sh.op – admin123

Você resolveu com sucesso o desafio: Password Strength (Log in with the administrator's user credentials without previously changing them or applying SQL Injection.)

<> Jump to related coding challenge

Acesso:

Você resolveu com sucesso o desafio: Admin Section (Access the administration section of the store.)

<> Jump to related coding challenge

Muito desafios, um deles é descobrir por meio da imagem e localização da senha de um usuario:

john@juice-sh.op que a senha é a localização da foto que ele tirou

Voce resolveu com sucesso o desafio: Login MC SafeSearch (Log in with MC SafeSearch's original user credentials without applying SQL injection or any other bypass.)

Voce resolveu com sucesso o desafio: Meta Geo Stalking (Determine the answer to John's security question by looking at an upload of him to the Photo Wall and use it to reset his password via the Forgot Password mechanism.)

do ETC:

Voce resolveu com sucesso o desafio: NFT Takeover (Take over the wallet containing our official Soul Bound Token (NFT).)

<> Jump to related coding challenge

Note: Never reveal your personal private keys and seed phrase to anyone



Juicy Chatbot SBT
Owned by 8343d2

Account Address
0x8343d2eb2B13A2495De435a1b15e85b98115Ce05

Descrição
Hurray! Find the Juice Shop SBT on [Opensea](#). This is a non-transferable token and is here to stay forever.

o de segurança é apenas entrar nos links do security.txt

localhost:3000/security.txt

Contact: <mailto:donotreply@owasp-juice.shop>
Encryption: https://keybase.io/bkimminich/pgp_keys.asc?fingerprint=19c01cb7157e4645e9e2c863062a85a8cbfbdca
Acknowledgements: [/#/score-board](#)
Preferred-languages: en, ar, az, bg, bn, ca, cs, da, de, ga, el, es, et, fi, fr, ka, he, hi, hu, id, it, ja, ko, lv, my, nl, no, pl, pt, ro, ru, si, sv, th, tr, uk, zh
Hiring: [/#/jobs](#)
Csaf: <http://localhost:3000/.well-known/csaf/provider-metadata.json>
Expires: Tue, 24 Aug 2027 17:04:13 GMT

o caso da emma é que o local onde ela trabalha ta na foto lá no painel de fotos: ITsec

Voce resolveu com sucesso o desafio: Visual Geo Stalking (Determine the answer to Emma's security question by looking at an upload of her to the Photo Wall and use it to reset her password via the Forgot Password mechanism.)

Esqueceu a Senha

Sua senha foi alterada com sucesso.

E-mail*

Pergunta de segurança*

Nova Senha*
Senha deve ter de 5-40 caracteres. 0/20

Confirme a Nova Senha* 0/20

☐ Exibir dica de senha

Alterar

Tem um que pede pra descriptografar ate achar o modelo MD5:

Você resolveu com sucesso o desafio: Weird Crypto (inform the shop about an algorithm or library it should definitely not use the way it does.)

X

Comentário dos Clientes

Nome

anonymous

Comentário*

MD5

Comentário máximo: 190 caracteres

3/190

Classificação

1

2

3

4

5

CAPTCHA

O que é 2-5+9-7

Resultado*

Por favor, insira o resultado da CAPTCHA.

Enviar

Das atividades 2 estrelas não consegui realizar tudo:

18 challenges are unavailable on Docker due to security concerns or technical incompatibility!
Hide disabled challenges

XSS Reflected XSS ★★ Problem: A reflected XSS attack with LFI traits. <pre>src=<script>alert('xss')</script></pre> (This challenge is potentially harmful via Docker) Tutorial · Zero browser · Run your demo locally	Sensitive Data Exposure Exposed Credentials ★★ A developer was careless with hardcoding unused, but still valid credentials for a testing account on the client-side Q01	Injection Login Admin ★★ Log in with the administrator's user account. Tutorial · Run your demo locally Web Coding Challenge	Broken Access Control Admin Section ★★ Access a seção administrativa da loja. Run your demo locally · Web Coding Challenge
Broken Authentication Password Strength ★★ Log in with the administrator's user credentials without previously changing them or applying SQL injection. Fetch Data · Tutorial · Web Coding Challenge	Broken Access Control View Basket ★★ View another user's shopping basket Tutorial · Run your demo locally	Broken Access Control AI Debugging ★★ Reveal some behind-the-scenes information on the chatbot as a non-admin user All LLM · Phishing LLM API	Injection Chatbot Prompt Injection ★★ Trick the chatbot into generating a coupon code for you despite its coupon policy banning otherwise Run your demo locally · All LLM · Web Coding Challenge
Security Misconfiguration Deprecated Interface ★★ Utilize deprecated WUI objects (see info for encouraged alternatives) // This challenge is potentially harmful on Docker Exploits · Passwords	Inproper Input Validation Empty User Registration ★★ Register a user with an empty email and password 1/1	Broken Access Control Five-Star Feedback ★★ Get rid of all 5-star customer feedback 0/02	Sensitive Data Exposure Login MC SafeSearch ★★ Log in with MC SafeSearch's original user credentials without applying SQL injection or any other bypass Manual · OSINT
Sensitive Data Exposure Meta Geo Stalking ★★ Determine the answer to John's security question by looking at an upload of him to the Photo Wall and use it to reset his password via the TripIt Password mechanism OSINT	Security Misconfiguration Misplaced IaC Files ★★ Access the misplaced Infrastructure as Code files that were accidentally included in the web application deliverable Privileges	Sensitive Data Exposure NFT Takeover ★★ Take over the wallet containing our official Soul Bound Token (NFT). Deception · Run your demo locally · Web	Sensitive Data Exposure Password Hash Leak ★★ Obtain the password (hash) of the currently logged-in user directly from a REST API endpoint 0/03
Miscellaneous Security Policy ★★ Behave like any "white hat" should before getting into the action Basic Patches	Sensitive Data Exposure Visual Geo Stalking ★★ Determine the answer to Emma's security question by looking at an upload of her to the Photo Wall and use it to reset her password via the TripIt Password mechanism OSINT	Cryptographic Issues Weird Crypto ★★ Inform the shop about an algorithm or library it should definitely not use the way it does 0/02	

Mas tentei bastante resolver.